

Sub-processor Schedule — Authentication Provider

This schedule governs processing carried out by the operator’s designated **Authentication Provider** — the party managing account credentials, session tokens, and JWKS-based token verification across all shyware embodiments. It is incorporated by reference into the Shyware Data Processing Agreement and is published at <https://shyware.fyi/legal/privacy/dpia/dpa/schedule-auth>.

Configuration trigger: This schedule applies to every shyware deployment. The `api.auth_scheme` field in shyconfig selects the mechanism (`cognito`, `jwt`, or equivalent). In all production deployments reviewed to date, the provider is AWS Cognito.

Role Definition

Field	Value
Sub-processor role	Authentication provider (account layer; session management; JWKS verification)
Named provider (operator completes)	REQUIRED_OPERATOR_INPUT (AWS Cognito in current deployments)
Contact for data protection	REQUIRED_OPERATOR_INPUT
Location	REQUIRED_OPERATOR_INPUT (AWS us-east-1 / us-east-2 in current deployments)
Transfer mechanism (if outside EEA)	REQUIRED_OPERATOR_INPUT (AWS SCCs available)

Dual Role: Account Layer and Delete-Only Authority

The authentication provider occupies two structurally distinct roles depending on the embodiment type:

- **Account layer (all 13 embodiments):** Cognito authenticates users at every API surface. The `sub` claim from the verified JWT is the primary input to the participant identity hash derivation written to List 2. This means the authentication provider holds the credential from which the canonical List 2 identity commitment is derived. A party with both Cognito access and the reconciling authority’s off-chain linkage store could link canonical submissions to accounts. This is the cross-authority collusion risk documented in all deployment DPIAs.
- **Delete-only authority (sealer-governed embodiments):** In shybrowser-v1, shystore-v1, shychat-v1, and all other sealer-governed embodiments where no separate eligibility authority key is registered at scoping-identifier creation, Auth (Cognito) serves as the **delete-only authority**. It holds the co-signature key required to execute rescissions. Every rescission is append-only in canonical state. Cognito cannot write, inflate, or fabricate canonical records — it can only co-sign deletion. This role is structurally enforced at the validation layer.

Data Processed

- Account credentials (username/email, hashed password, MFA state)
- Session tokens (JWT access token, refresh token, ID token)
- Account **sub** claim — the stable account identifier used to derive the participant identity hash written to List 2
- Auth events (sign-in, sign-out, token refresh, MFA challenge, account recovery)
- JWKS public keys — used server-side to verify token signatures
- Account metadata (creation date, last sign-in, account status)

Critical Data Flow: sub Claim to List 2

The **sub** claim is the stable, opaque account identifier issued by Cognito. The shyware server derives the participant identity hash as:

```
identity_hash = SHA-256(sub || scoping_id || domain_separator)
```

This hash is written to List 2 of the canonical ledger with no submission payload. This means:

- A party holding Cognito’s user directory AND the canonical List 2 records cannot derive the submission direction from List 2 alone — the hash is a one-way function and the submission direction is in List 1, separated structurally.
- A party holding Cognito’s user directory AND the reconciling authority’s off-chain linkage store (which maps identity hash to submission ID) CAN link an account to a specific canonical submission. This is the cross-authority collusion vector.
- The authentication provider alone cannot reconstruct the identity–submission association because it does not hold the off-chain linkage store.

Operator obligation: The privacy notice must disclose that the authentication provider holds credentials from which List 2 identity hashes are derived, and that cross-authority collusion between the authentication provider and the reconciling authority would break structural anonymity. This disclosure is required under Art. 13 GDPR and is non-negotiable for any deployment.

Special Category Obligations

The authentication provider does not itself process special-category data. However, if the deployment processes special-category data (health records, political opinions, biometric data), the legal basis for the authentication processing must be compatible with the lawful basis for the special-category processing. In particular, consent-based special-category processing requires that authentication is not conditioned in a manner that makes consent to special-category processing involuntary.

Structural Constraints

- **Cannot write canonical records:** The authentication provider has no canonical commit authority. It cannot write List 1 or List 2 records directly.
- **Cannot access off-chain linkage store:** The authentication provider does not hold the reconciling authority's off-chain linkage data.
- **Delete-only in sealer embodiments:** Where Cognito serves as delete-only authority, it may only co-sign rescissions. It cannot initiate rescissions unilaterally without the reconciling authority's co-signature.
- **Key independence:** At scoping-identifier creation, the `eligibility_authority_key` (if registered) must differ from the `reconciling_authority_key` and from the auth account credentials. Three-authority key independence is a required pre-production check.
- **Cross-authority collusion is the residual risk:** The structural non-linkability guarantee holds unless Cognito and the reconciling authority collude. Operator must assess this risk in deployment DPIA and implement access controls, logging, and contractual separations to reduce it.

Operator Obligations

- Execute a signed DPA with the authentication provider before processing any personal data.
- Disclose the `sub-to-List-2` derivation path in the operator's privacy notice.
- Configure Cognito to minimize data collection: disable unused attributes, configure shortest viable token expiry, enable log-level controls.
- In sealer-governed embodiments, document and test the delete-only co-signature pathway for the authentication provider key.
- Verify at scoping-identifier creation that the authentication provider's key is independent of the eligibility authority key and reconciling authority key.
- Confirm SCCs or adequacy decision if Cognito processes EU personal data in a non-EEA region.
- Notify Shyware of any change of authentication provider at least 30 days in advance.

Audit and Retention

Auth event logs must be retained for the period required by applicable law and for the duration necessary to support data subject access requests (Art. 15) and erasure requests (Art. 17). Account deletion must propagate to: Cognito user pool, off-chain linkage store (via reconciling authority co-signed rescission), and any session token caches. Note that deleting the Cognito

account does not automatically delete the List 2 identity hash in canonical state — canonical deletion requires a separate rescission transaction co-signed by the delete-only authority.

This schedule is incorporated by reference into the Shyware Data Processing Agreement and is published at <https://shyware.fyi/legal/privacy/dpia/dpa/schedule-auth>.